

WEB SECURITY LABS

Beginner's Guide to Reflected XSS

1. What is Reflected XSS?

Reflected Cross-Site Scripting (XSS) is a vulnerability where untrusted user input is immediately reflected into a webpage without proper sanitization or encoding. The browser interprets the injected content as executable JavaScript.

2. How Reflected XSS Works

A vulnerable application reflects user-controlled input directly into the page.

If malicious JavaScript is included in the input, the browser executes it.

This often occurs in search boxes, error messages, or URL parameters.

3. Vulnerable Example

```
search = request.GET['q']  
response = "<h2>Results for: " + search + "</h2>"
```

4. Classic Payload Demonstration

Payload Example:

```
<script>alert('XSS')</script>
```

The application reflects the payload into the webpage, and the browser executes the injected script.

5. Request Flow & Browser Execution

[User Browser] → Enters malicious payload

[Vulnerable Web App] → Reflects unsanitized input

[Browser Rendering Engine] → Parses injected script

[Script Executes] → JavaScript runs in browser

6. Risks & Impacts

Session hijacking

Cookie theft

Fake login pages

Defacement

User impersonation

Malware injection

7. Prevention & Mitigation

INSECURE:

```
innerHTML = userInput
```

SECURE:

```
textContent = userInput
```

Use output encoding, Content Security Policy (CSP), and safe DOM APIs.

EDUCATIONAL DISCLAIMER & NOTICE

These sandbox labs are designed solely for safe, local cybersecurity education. Never test, scan, or attack systems you do not own or have explicit authorization to assess. Unauthorized testing is illegal.